

Row	Defense Strategy	Target Layer	FR Target	Mitigation Implementation for SL 2	Tangible Industry Example
1	Physical Security	Physical	FR 1, FR 7	Restrict physical access to PLC panels, network switches, and engineering ports so only authorized personnel can connect a Modbus master/client. Enforce controlled maintenance procedures (approved laptops, supervised sessions) and protect any security keys/credentials used by gateways or security add-ons from theft. Treat “physical access to the OT network” as equivalent to “Modbus control,” because Modbus itself does not authenticate endpoints.	CVE-2021-22779 (ModiPwn – Schneider Electric Modicon PLC takeover): Attackers with network access could bypass protections and abuse undocumented Modbus-related behavior to gain deep control over affected PLCs, including actions like overwriting critical memory regions. If an attacker can plug into an exposed switch port or cabinet Ethernet, they can become “on-network” and exploit such weaknesses. Physical restriction of ports/panels reduces the chance of initial access to the Modbus/PLC network and therefore reduces exploitability and impact.
2	Boundary Protection	Network	FR 5, FR 7	Implement zoning and conduits: keep Modbus TCP (port 502) inside the OT zone, block direct IT→OT access, and force remote access through a controlled DMZ/jump path. Only allow Modbus TCP from known SCADA/gateway IPs to known PLC IPs (default-deny). This reduces exposure and prevents opportunistic scanning or unauthorized clients from reaching PLCs.	CVE-2019-6856 (Schneider Electric Modicon Controllers – Modbus TCP DoS via write to physical memory blocks): A vulnerability in several Modicon PLC lines could be triggered over Modbus TCP to cause a denial of service when writing specific physical memory blocks. If Modbus/502 is reachable broadly, an unauthenticated attacker on the network can attempt to trigger this condition remotely. Proper boundary firewalls/segmentation reduce the reachable attack surface so only approved hosts can even send Modbus traffic to the PLC.
3	Protocol Enforcement	Network / Application	FR 2, FR 3, FR 6	Deploy Modbus-aware enforcement in-line (secure gateway/proxy or DPI firewall). Apply allowlists for: (1) permitted Modbus function codes, (2) permitted register ranges, and (3) permitted client IPs. Block or alarm on write-capable function codes (e.g., 0x05/0x06/0x10) unless explicitly required, and drop malformed/abnormal Modbus frames. This prevents “legitimate Modbus commands used maliciously” and reduces replay and spoofing opportunities when combined with a controlled access path.	CVE-2017-6034 (Schneider Electric Modicon Modbus Protocol – Authentication bypass by capture/replay): The issue describes a capture-replay style weakness where sensitive operations could be replayed because information/commands were transmitted in cleartext, enabling replay of commands such as run/stop/upload/download. Protocol enforcement helps by restricting which commands/functionality are allowed and from where—reducing the set of operations that can be replayed successfully. When placed at a gateway/DPI firewall, it can also detect abnormal sequences and block unauthorized operations even if Modbus messages “look valid.”
4	Controller Hardening	Application	FR 3, FR 7	Harden Modbus servers/PLCs and any Modbus libraries/components used in gateways or HMIs: patch firmware/software, disable unused services, and apply conservative parsing/limits to reduce malformed-frame crashes. Apply operational restrictions such as “read-only by default” during normal operation (writes only during controlled maintenance) and configure PLC logic to validate setpoint ranges so even permitted writes can’t push unsafe values.	CVE-2024-10918 (libmodbus v3.1.10 – stack-based buffer overflow / unexpected response length): NVD describes a stack-based overflow condition in libmodbus where unexpected lengths during response handling can overflow a buffer (impacting integrity/availability). In real deployments, libmodbus can appear in gateways, data collectors, or OT tooling—so hardening includes updating the component, adding bounds checking via vendor fixes, and restricting exposure of Modbus endpoints to trusted hosts only. Patching + service minimization reduces the chance of malformed traffic causing crashes or unstable behavior.
5	Secure Communication	Network / Transport	FR 1, FR 3, FR 4, FR 6	Deploy a security wrapper/proxy in front of Modbus TCP endpoints that adds cryptographic protection to Modbus exchanges. The wrapper encrypts the Modbus payload and applies integrity/authenticity checks (e.g., signature/MAC) so packets cannot be altered or forged in transit. Implement anti-replay protection by including freshness data (e.g., counters/hash-chain synchronization) and rejecting duplicated/old messages. Keep legacy PLCs unchanged by terminating the secure channel at the gateway and forwarding only validated Modbus to the controller.	CVE-2017-6034 – Schneider Electric Modicon Modbus “Capture-Replay Authentication Bypass”: The issue describes that sensitive Modbus-related commands are transmitted in cleartext, allowing an attacker who can capture traffic to replay commands such as run/stop/upload/download. A secure wrapper (encryption + integrity + freshness) prevents this by making captured packets unusable: replayed traffic fails the integrity/freshness checks and is rejected before reaching the PLC.
6	Monitoring & Intrusion Detection	Network / System	FR 6, FR 7	Implement passive monitoring (SPAN/mirror-port) with a Modbus-aware sensor to detect abnormal patterns such as new/unknown Modbus clients, unexpected function codes, unusual register access, malformed packets, or repeated failures indicative of probing. Use detection logic to flag replay/false-command behaviors and generate alerts to operators; optionally integrate “block on alert” via firewall automation or by placing the sensor at/near a security gateway. Maintain baseline behavior (normal polling rates, normal function codes) and alert on deviations.	CVE-2021-22659 – Rockwell Automation MicroLogix 1400 “Specially Crafted Modbus Packet DoS”: A remote unauthenticated attacker may send a specially crafted Modbus packet that can lead to a buffer overflow and denial-of-service, with communications loss and fault LED behavior; recovery may require manual fault clearing. A Modbus-aware monitoring sensor can detect the lead-up (unexpected packet structures, abnormal request sizes/rates, repeated failures) and trigger early alerts, helping operators isolate the source and block the traffic before prolonged outage.

7	Key & Credential Management	System / Organizational	FR 1, FR 2, FR 3	Treat cryptographic keys and gateway credentials as critical assets: provision keys securely, store them in protected locations on the gateway, and restrict who can export or modify them. Use unique credentials per device/service, disable insecure management services where possible, and enforce lifecycle practices (rotation/replacement after maintenance or suspected exposure). Align key use with the security mechanism chosen: shared secret keys for MAC-based integrity systems and certificate/private-key handling for signature/TLS-style systems, ensuring only authorized endpoints can participate.	CVE-2019-6549 – PR100088 Modbus Gateway “Plaintext Credentials Exposure via FTP”: The vulnerability description states an attacker could retrieve plain-text credentials stored in an XML file on affected Modbus gateway versions through FTP. This is a real example of key/credential handling failure in a Modbus ecosystem component. Strong credential management (disable/secure management services, protect credential files, rotate credentials, restrict access) would reduce the chance of credential theft and subsequent unauthorized access to downstream OT systems.
---	-----------------------------	-------------------------	------------------	---	--

Row	Defense Strategy	Target Layer	FR Target	Mitigation Implementation for SL 2	Tangible Industry Example
1	Physical Security	Physical	FR 1 - Access Control, FR 7- Resource Availability	Restrict direct physical access to PROFINET PLCs, I/O devices, switches, and engineering ports. Use locked control cabinets and badge-based access in OT rooms. Prevent unauthorized personnel from plugging laptops into spare switch ports, which would immediately grant Layer-2 adjacency to PROFINET cyclic and DCP broadcast traffic. Since classic PROFINET lacks authentication for Configuration & Identification (e.g., DCP), “physical network access” implies “logical control influence.”	CVE-2016-4785 — Siemens EN100 Module: Unauthorized Information Disclosure via Web Interface Attackers with network adjacency could retrieve configuration data from EN100 communication modules (used in protection relays), including device name, IP, and PROFINET configuration parameters, without authentication. Physical cabinet hardening helps prevent unauthorized LAN adjacency and thereby reduces information leakage risks that enable subsequent PROFINET spoofing/reconfiguration attacks.
2	Boundary Protection	Network	FR 5 - Restricted Data flow	Apply zoning and conduits as defined in IEC 62443-3-3 to keep Profinet Traffic within the automation cell. Use VLAN and Industrial Firewall to ensure DCP and realtime traffic never crosses into IT networks. Apply default-deny routing so that only authorized PLC engineering Stations and IO devices can exchange PROFINET traffic. Prevent Opportunistic scanning and unauthorized cyclic Associations (AR establishment).	CVE-2019-13946 — Siemens PROFINET IO Stack Denial-of-Service The PNIO stack handled specific diagnostic requests incorrectly, allowing unauthenticated attackers with L2 access to exhaust memory and disrupt cyclic IO communication. Without network segmentation, attackers in IT/enterprise zones could reach the PNIO stack and remotely trigger availability loss. Proper boundary protection narrows reachable attack surface to authorized engineering stations.
3	Protocol Enforcement	Network / Application	FR 2 - Authorization, FR 3 - System Integrity, FR 6- Confidentiality	Install PROFINET-aware DPI or secure gateways to enforce allowed device interactions. Restrict DCP SetName/SetIP operations (used for device configuration), enforce valid Application Relation (AR) establishment sequences, and alarm on spoofed MAC identities . Reject malformed PNIO frames and unexpected cyclic/acyclic combinations. This prevents silent misuse of valid PROFINET semantics such as device renaming and PLC impersonation.	CVE-2021-20986 — Hilscher PROFINET Device Stack Memory Corruption Malformed PROFINET frames could corrupt memory in multiple industrial field devices, leading to persistent communication failure and device disappearance from network discovery. DPI/protocol enforcement can detect malformed PNIO frames and prevent propagation to susceptible devices, reducing availability impact even for zero-day parsing flaws.
4	Controller Hardening	Application	FR 1- Identification & Authentication, FR 2- Use Control, FR 3- System Integrity, FR 7- Resource Availability	Harden PROFINET device stacks with firmware patching, secure boot, role-based access control on engineering functions, and . Disable unused services such as web/FTP interfaces on PLCs, enforce signed firmware access , and validate configuration parameter ranges so that even legitimate PN data cannot drive unsafe plant states.	Siemens SIMATIC Controllers (Unchecked Inputs Leading to Logic Manipulation/State Corruption) Improper boundary checks allowed malformed input sequences to affect process states. Hardening through bounds checking and signed firmware updates mitigates such issues and reduces the attack surface for state manipulation or DoS.
5	Monitoring & Detection	Network / System	FR 6 Timely Response to Events, FR 7- Resource Availability	Use passive network monitoring via mirror ports/SPAN or probes with PROFINET decoders to detect DCP spoofing, replay behavior, rapid AR teardown/creation cycles, or abnormal PNIO timing. Maintain cyclic traffic baselines and alert when a device is renamed or disappears from AR mapping — typical indicators for hijack or DoS attacks . Integrate detection with SOC or OT incident workflows.	CVE-2016-4785 and CVE-2019-13946 both show that attackers often require only adjacency to perform disruptive actions. Monitoring detects these behaviors before full outage by identifying AR disruption events, DCP floods, or abnormal diagnostic request rates — giving operators time to block or quarantine the source.
6	Key & Credential Management	System / Organizational	FR 1, FR 2, FR 3	Implement rate limiting on PROFINET diagnostic requests , reserve CPU/memory for cyclic data, and ensure watchdog mechanisms recover IO communication on fault conditions. Prioritize cyclic channels over engineering channels, so malicious acyclic floods cannot starve deterministic traffic. Combine with firmware improvements to handle malformed packet error paths safely.	CVE-2021-20986 and CVE-2019-13946 (DoS-class vulnerabilities in PNIO stacks) Both vulnerabilities show malformed or repeated PROFINET frames could cause persistent DoS requiring manual restart. DoS-resilient scheduling and bounds-checking reduces the chance that malformed cyclic/acyclic interactions crash devices or take them offline.